ACTIVIDAD 09 · SESIÓN DE SEGURIDAD · TRABAJO EN CASA · INDIVIDUAL

# RÚBRICA DEL RETO DE SEGURIDAD

CTF local: tres contratos vulnerables, tres exploits, Slither sobre tu propio proyecto y preguntas de reflexión. Autocalificable: la prueba en verde es parte de tu nota.

| MODALIDAD | ENTREGA | ESCALA | FECHA |
|---|---|---|---|
| **Individual · en casa sin profesor** | **Atacantes.sol · capturas Slither · reflexión** | **100 puntos (= nota de la actividad)** | **viernes 30 de octubre de 2026** |

**CÓMO FUNCIONA ESTA RÚBRICA**

Cada reto vale **25 puntos**: **20** son automáticos (la prueba del CTF pasa o no pasa) y **5** son por explicar, con tus palabras, por qué el contrato era vulnerable y cómo se arreglaría. Slither sobre tu propio contrato vale **10** y las preguntas de reflexión **15**. Total: **100**. La prueba en verde la puedes verificar tú mismo antes de entregar con `npx hardhat test test/s09/ctf/CTF.test.js`.

## 01 Resumen de pesos

100 PUNTOS

| COMPONENTE | PUNTOS | REPARTO INTERNO |
|---|---|---|
| Reto 1 · control de acceso (tx.origin) | 25 | Prueba en verde 20 · explicación 5 |
| Reto 2 · azar en cadena | 25 | Prueba en verde 20 · explicación 5 |
| Reto 3 · reentrada | 25 | Prueba en verde 20 · explicación 5 |
| Slither sobre tu proyecto | 10 | Ejecución 5 · lectura de hallazgos 5 |
| Preguntas de reflexión | 15 | 4 preguntas, ver sección 04 |

## 02 Los tres retos · 75 puntos

20 AUTO + 5 ARGUMENTO

Las tres filas aplican igual a cada reto (1, 2 y 3). La parte automática es la prueba del archivo `test/s09/ctf/CTF.test.js`; la parte de argumento son las 3 a 5 líneas que entregas por cada reto.

| CRITERIO | PUNTOS | QUÉ SE ESPERA |
|---|---|---|
| **Exploit funciona** | 20 | La prueba del reto queda **en verde** (`passing`). Es automático: pasa (20) o no pasa (0). A juicio del docente, un exploit casi correcto que falla por un detalle menor puede recibir crédito parcial (hasta 12). |
| **Explica el porqué** | 3 | Nombra la causa **exacta** del fallo (la línea o el patrón: `tx.origin`, el número recalculable, el envío antes de poner el saldo en cero), no una frase genérica. |
| **Propone la defensa** | 2 | Dice **cómo se arreglaría** de forma correcta (usar `msg.sender`; oráculo de azar / commit–reveal; Checks–Effects–Interactions o `ReentrancyGuard`). |

BANDAS PARA LA PARTE DE ARGUMENTO (5 PUNTOS POR RETO)

| NIVEL | PUNTOS | DESCRIPCIÓN |
|---|---|---|
| **Completo** | 5 | Identifica la causa exacta y da una defensa correcta y concreta. |
| **Parcial** | 2–3 | Ve el fallo pero la defensa es vaga, incompleta o solo «parchada». |
| **Insuficiente** | 0–1 | Explicación genérica, copiada o incorrecta; no demuestra haber entendido. |

## 03 Slither sobre tu proyecto · 10 puntos

TU CONTRATO, NO LOS RETOS

| CRITERIO | PUNTOS | QUÉ SE ESPERA |
|---|---|---|
| **Ejecución** | 5 | Captura de Slither corrido sobre el contrato principal de **tu** proyecto del curso, con la línea `N result(s) found`. Si importa OpenZeppelin, se ve el uso de `--solc-remaps`. |
| **Lectura** | 5 | Por cada hallazgo: nombre, severidad y si es real o falso positivo **en tu caso**, con una frase que lo justifique. Separar señal de ruido es el punto. |

Si tu sala no permite instalar Python, se acepta la extensión de VS Code de Slither o una alternativa web, dejándolo dicho en la evidencia.

## 04 Preguntas de reflexión · 15 puntos

MIRA TU CÓDIGO REAL

| PREGUNTA | PUNTOS | SE EVALÚA |
|---|---|---|
| 1 · tx.origin vs msg.sender: qué línea cambiar para romper tu ataque del reto 1 y por qué. | 4 | Correcta y concreta. |
| 2 · Por qué ningún dato en cadena da azar real, y de dónde debería venir. | 4 | Argumento, no definición. |
| 3 · La única línea a mover en `retirar()` y su costo en gas, atado a C-E-I. | 4 | Exactitud. |
| 4 · Cuál de las tres familias podría sufrir tu propio proyecto, señalando la función. | 3 | Mira su propio código. |

**RESPUESTAS GENÉRICAS = 0 EN LA PREGUNTA**

Estas preguntas se responden mirando **tu** contrato y **tu** exploit. Una respuesta que valdría igual para cualquier curso —la que produce un asistente sin tu código— no recibe puntos, aunque esté «bien escrita».

## 05 Declaración de uso de IA y honestidad

Puedes usar asistentes de IA, pero debes **declararlo**. Estos retos no se ganan pegando una respuesta que no entiendes: la parte de argumento y la reflexión miden tu criterio de seguridad, que es justo lo que un asistente taparía. Entregar algo que no comprendes —aunque la prueba pase— y no poder sostener el porqué es motivo de anulación de los puntos de argumento y reflexión.

**COMPLETA Y FIRMA AL ENTREGAR**

Declaro que este trabajo es mío. Usé asistentes de IA de la siguiente manera (herramienta y para qué; escribe «no usé» si aplica):

_____

_____

NOMBRE Y APELLIDO _____ CÓDIGO _____ FECHA _____